CRISC Mixed Practice Exam II – 100 Real-Life Questions

Weighted to the Four CRISC Domains – Practical Scenarios

CRISC Mastery Series

October 25, 2026

Instructions

How to Use This Deck

Think like a risk practitioner in a real organization.
Focus on business context, ownership, and practical decision-making.
The answer and a key takeaway are on the slide following each question.

Outline

1. Governance (26 percent of the exam)
2. Risk Assessment (20 percent of the exam)
3. Risk Response and Reporting (32 percent of the exam)
4. Information Technology and Security (22 percent of the exam)
5. Conclusion

Q1: Risk Policy Contents

Question

Which element is **MOST** essential in an enterprise risk management policy?

(A) A list of approved software

(B) Employee dress standards

(C) Office seating plans

(D) Defined roles, risk appetite alignment, and required processes for identifying, assessing, responding to, and reporting risk

Q1: Explanation

Correct Answer: D

- Policy sets the framework for risk activities.
- Roles create accountability.
- Alignment to appetite guides decisions.

Key Takeaway

A risk policy defines who does what, and to what standard.

Q2: CISO Reporting Line

Question

The CISO reports to the CIO, and security concerns are often overridden for cost reasons. What is the **BEST** governance improvement?

(A) Remove the CISO role

(B) Make the CISO report to the help desk

(C) Hide security concerns

(D) Give the CISO a reporting line or access that supports independence, such as direct access to senior executives or the board

Q2: Explanation

Correct Answer: D

- Independence reduces conflicts of interest.
- Senior access ensures material risks are heard.
- Trade-offs should be visible to decision makers.

Key Takeaway

Risk voices need a path to the top.

Q3: Key Person Dependency

Question

Only one engineer understands a critical system. What is the **BEST** risk response?

(A) Accept the risk forever with no action

(B) Document the system, cross-train staff, and establish succession and backup coverage

(C) Prevent the engineer from taking vacation

(D) Delete the system documentation

Q3: Explanation

Correct Answer: B

- Single points of failure include people.
- Knowledge sharing reduces dependency.
- Succession planning supports resilience.

Key Takeaway

People can be single points of failure too.

Q4: Tone at the Top

Question

Executives routinely bypass security controls for their own convenience. What is the **MOST** significant effect?

(A) It strengthens controls

(B) It undermines the risk culture because staff follow leaders' behavior rather than written policy

(C) It has no effect

(D) It improves audit results

Q4: Explanation

Correct Answer: B

- Leaders shape norms.
- Exemptions without approval erode trust.
- Consistent standards support compliance.

Key Takeaway

Staff copy what leaders do.

Q5: Management Override

Question

Which control is **MOST** effective against management override of financial and IT controls?

(A) Trusting executives completely

(B) Eliminating all controls

(C) Independent review, monitoring of overrides, and a whistleblower channel

(D) Annual training only

Q5: Explanation

Correct Answer: C

- Override is a known fraud risk.
- Independent oversight detects abuse.
- Reporting channels expose violations.

Key Takeaway

Watch the people who can bypass the controls.

Q6: Whistleblower Policy

Question

What is the primary purpose of a whistleblower policy?

(A) To enable staff to report misconduct or risk concerns safely, without retaliation

(B) To punish complainers

(C) To reduce paperwork

(D) To publicize employee names

Q6: Explanation

Correct Answer: A

- Safe reporting surfaces hidden risk.
- Anti-retaliation protection builds trust.
- Independent handling ensures fairness.

Key Takeaway

Safe reporting reveals risk.

Q7: ISO 31000

Question

An organization wants a general, industry-neutral guideline for risk management principles and process. Which standard **BEST** fits?

(A) A cabling specification

(B) A coding language standard

(C) A paper size standard

(D) ISO 31000

Q7: Explanation

Correct Answer: D

- ISO 31000 provides principles and a process.
- It applies to many organization types.
- It complements, not replaces, domain frameworks.

Key Takeaway

ISO 31000 is the general risk management guideline.

Q8: ISO 27001

Question

Management wants an internationally recognized, certifiable approach for establishing an information security management system. Which standard fits?

(A) ISO 9660

(B) ISO 8601

(C) ISO 4217

(D) ISO/IEC 27001

Q8: Explanation

Correct Answer: D

- 27001 specifies ISMS requirements.
- Certification is by independent bodies.
- It is risk-based.

Key Takeaway

27001 is the certifiable ISMS standard.

Q9: COSO Concept

Question

Which framework is **MOST** associated with enterprise risk management integrated with strategy and performance?

(A) A network protocol standard

(B) A programming framework

(C) COSO Enterprise Risk Management framework

(D) A building code

Q9: Explanation

Correct Answer: C

- COSO ERM links risk to strategy.
- It is widely used for governance.
- It complements IT frameworks.

Key Takeaway

COSO ERM ties risk to strategy and performance.

Q10: Quantitative Framework

Question

Which framework is specifically designed for quantifying information risk in financial terms?

(A) A color-coding scheme

(B) A password standard

(C) Factor Analysis of Information Risk (FAIR)

(D) A seating chart

Q10: Explanation

Correct Answer: C

- FAIR models loss event frequency and magnitude.
- Outputs support cost-benefit analysis.
- It needs sound input data.

Key Takeaway

FAIR quantifies risk in dollars.

Q11: Maturity Targets

Question

Management sets a maturity target of the highest level for every process. What is the **BEST** challenge?

(A) Agree to the highest level always

(B) Set targets based on business need and risk, since the highest maturity everywhere may not be cost-justified

(C) Remove all targets

(D) Use random targets

Q11: Explanation

Correct Answer: B

- Maturity should match value and risk.
- Resources are limited.
- Priorities should be explicit.

Key Takeaway

Target maturity by need, not by ambition.

Q12: Benchmarking

Question

A board compares its security spending to a peer average. What is the **PRIMARY** limitation?

(A) Benchmarks are always illegal

(B) Peers have different risk profiles, so benchmarks do not show whether spending matches this organization's risk

(C) Peers never spend anything

(D) Benchmarks are perfectly precise

Q12: Explanation

Correct Answer: B

- Risk appetite and exposure differ.
- Benchmarks are useful context only.
- Decisions should rest on own risk.

Key Takeaway

Benchmarks inform; risk decides.

Q13: Policy Sunset

Question

A policy has no owner or review date. What is the **BEST** governance action?

(A) Ignore it

(B) Delete it without review

(C) Assign an owner and set a review cycle, then retire or update the policy accordingly

(D) Enforce it as is

Q13: Explanation

Correct Answer: C

- Ownership drives maintenance.
- Review dates keep policies current.
- Retirement avoids conflicting guidance.

Key Takeaway

Every policy needs an owner and a review date.

Q14: Regulatory Examination Readiness

Question

A regulatory examination is scheduled in three months. What should the risk practitioner do?

(A) Assess readiness, close known gaps, and ensure evidence is organized and accurate

(B) Wait for the examiners to arrive

(C) Alter documents to look better

(D) Avoid preparation

Q14: Explanation

Correct Answer: A

- Preparation reduces findings.
- Evidence must be truthful.
- Known gaps should be disclosed with plans.

Key Takeaway

Be ready, be honest.

Q15: Records Retention Governance

Question

Departments keep records under inconsistent retention rules. What should governance implement?

(A) A records retention schedule based on legal and business requirements, with defined disposal procedures

(B) Keep everything forever

(C) Delete records daily

(D) Let each person decide

Q15: Explanation

Correct Answer: A

- Retention reduces legal and storage risk.
- Legal obligations differ by record type.
- Disposal should be secure.

Key Takeaway

Retain what is required, dispose of the rest.

Q16: Cyber Expertise on the Board

Question

The board lacks cyber risk knowledge. What is the **BEST** approach?

(A) Provide education and use qualified advisors or committees to support informed oversight

(B) Ignore cyber topics

(C) Delegate all decisions to IT

(D) Avoid reporting cyber risk

Q16: Explanation

Correct Answer: A

- Oversight requires understanding.
- Advisors provide expertise.
- Education builds long-term capability.

Key Takeaway

Boards must understand enough to oversee.

Q17: Balanced Scorecard

Question

How does a balanced scorecard help IT governance?

(A) It lists server names

(B) It replaces strategy

(C) It prevents attacks

(D) It links IT performance measures to business objectives across financial, customer, process, and learning perspectives

Q17: Explanation

Correct Answer: D

- It translates strategy into measures.
- It balances short- and long-term views.
- It supports alignment.

Key Takeaway

Scorecards align IT measures to strategy.

Q18: Risk Acceptance Register

Question

Why maintain a central register of accepted risks?

(A) To provide transparency, ensure periodic review, and keep accountability for accepted exposures

(B) To hide risks from auditors

(C) To avoid reviews

(D) To remove owners

Q18: Explanation

Correct Answer: A

- Accepted risks should not be forgotten.
- Reviews confirm continued validity.
- Visibility supports governance.

Key Takeaway

Accepted does not mean forgotten.

Q19: Anti-Fraud Controls

Question

Which IT control **BEST** supports fraud prevention in financial systems?

(A) Segregation of duties, access reviews, and transaction monitoring

(B) Shared administrator passwords

(C) Unlimited access

(D) No logging

Q19: Explanation

Correct Answer: A

- Fraud exploits access and weak oversight.
- Monitoring detects anomalies.
- Separation limits abuse.

Key Takeaway

Limit access, separate duties, watch transactions.

Q20: Third-Party Ethics

Question

A key supplier is accused of using forced labor. What is the **BEST** first step?

(A) Ignore the allegation

(B) Publicly condemn without facts

(C) Assess the credibility and impact, engage the vendor, and escalate through governance and compliance channels

(D) Hide the information

Q20: Explanation

Correct Answer: C

- Ethical issues create reputational and legal risk.
- Fact-finding comes before decisions.
- Governance decides the response.

Key Takeaway

Investigate, then escalate.

Q21: Governance Metrics

Question

Which metric **BEST** indicates effective risk governance?

(A) Number of pages in reports

(B) Number of committee meetings

(C) Timely risk decisions made by accountable owners within appetite, and acted-on escalations

(D) Number of risks hidden

Q21: Explanation

Correct Answer: C

- Outcomes matter more than activity.
- Accountability shows maturity.
- Escalations demonstrate functioning oversight.

Key Takeaway

Governance is judged by decisions and follow-through.

Q22: Strategy and Technology Debt

Question

Years of postponed upgrades have created large technology debt. How should this be governed?

(A) Ignore it

(B) Hide it from the board

(C) Treat it as an IT-only problem

(D) Track technical debt as a risk with owners and funding decisions aligned to appetite

Q22: Explanation

Correct Answer: D

- Debt increases failure and security risk.
- Owners and plans are needed.
- Funding is a business decision.

Key Takeaway

Technical debt is business risk.

Q23: Risk Practitioner Independence

Question

A risk practitioner is evaluated by the manager of the department being assessed. What is the concern?

(A) None, all is fine

(B) Practitioners should avoid assessments

(C) Managers cannot evaluate anyone

(D) Objectivity may be compromised, so the reporting line should support independence

Q23: Explanation

Correct Answer: D

- Evaluations can pressure ratings.
- Independent reporting protects objectivity.
- Governance should address it.

Key Takeaway

Do not assess the person who controls your career.

Q24: Time-Bound Governance Decisions

Question

Governance decisions on risk responses take months, leaving risks exposed. What is the **BEST** fix?

(A) Wait longer

(B) Skip decisions

(C) Define decision timelines and delegated authority based on risk level

(D) Ban governance meetings

Q24: Explanation

Correct Answer: C

- Timeliness affects exposure.
- Delegation speeds routine decisions.
- Higher risks still escalate.

Key Takeaway

Governance must move at the speed of risk.

Q25: Risk Appetite Statement Quality

Question

Which risk appetite statement is **BEST** for operational use?

(A) We want to be safe

(B) We tolerate no more than four hours of outage for customer-facing systems and zero unmitigated critical vulnerabilities older than 30 days

(C) We avoid all risk

(D) We will do our best

Q25: Explanation

Correct Answer: B

- Good statements are specific and measurable.
- They can be monitored with indicators.
- Vague statements cannot guide decisions.

Key Takeaway

Appetite statements must be measurable.

Q26: Linking Risk to Performance

Question

How can risk management **BEST** be integrated with business performance management?

(A) By keeping risk separate

(B) By including risk indicators and appetite in planning, performance reviews, and decision making

(C) By reporting risk only to audit

(D) By ignoring risk during planning

Q26: Explanation

Correct Answer: B

- Integrated risk supports strategy.
- Indicators inform trade-offs.
- Decisions should reflect appetite.

Key Takeaway

Risk belongs in planning and performance conversations.

Q27: Delphi Technique

Question

Which technique collects anonymous expert estimates over several rounds to reach consensus?

(A) The Delphi technique

(B) A brainstorm among executives only

(C) A random poll

(D) A vendor presentation

Q27: Explanation

Correct Answer: A

- Anonymity reduces dominance bias.
- Iteration refines estimates.
- Consensus improves reliability.

Key Takeaway

Delphi means anonymous rounds of expert input.

Q28: Bow-Tie Analysis

Question

What does a bow-tie diagram help the risk practitioner visualize?

(A) Causes, the central risk event, consequences, and the preventive and recovery controls between them

(B) Employee schedules

(C) Network cable routes

(D) Financial statements only

Q28: Explanation

Correct Answer: A

- It links causes to consequences.
- Preventive controls sit on the cause side.
- Recovery controls sit on the consequence side.

Key Takeaway

Bow-ties show causes, event, consequences, and controls.

Q29: Attack Frameworks

Question

A team wants a common catalog of adversary tactics and techniques to design detections and assess coverage. What **BEST** fits?

(A) A purchasing catalog

(B) A chart of accounts

(C) A coding style guide

(D) The MITRE ATT&CK knowledge base

Q29: Explanation

Correct Answer: D

- It structures real-world attacker behavior.
- Coverage mapping highlights gaps.
- It supports threat-informed defense.

Key Takeaway

ATT&CK maps adversary behavior to detections.

Q30: Kill Chain

Question

Which concept describes the stages of an attack from reconnaissance to actions on objectives, helping defenders find opportunities to disrupt?

(A) The cyber kill chain

(B) A supply chain schedule

(C) A reporting chain of command

(D) A key chain inventory

Q30: Explanation

Correct Answer: A

- Stages show where to detect or block.
- Earlier disruption reduces impact.
- Defense in depth maps to stages.

Key Takeaway

Break the chain early.

Q31: Likelihood Scale Definition

Question

Assessors interpret terms like unlikely and possible differently. What is the **BEST** improvement?

(A) Use vague words only

(B) Let each assessor decide

(C) Use only the highest level

(D) Define each likelihood level with clear descriptions, such as ranges for frequency or probability

Q31: Explanation

Correct Answer: D

- Clear definitions reduce subjectivity.
- Consistency enables comparison.
- Scales should be approved.

Key Takeaway

Define the scale, then use it.

Q32: Control Effectiveness Rating

Question

How should control effectiveness be determined for inclusion in a risk assessment?

(A) By evidence from testing, monitoring, and incidents rather than by design intent alone

(B) By the vendor's brochure

(C) By the control owner's confidence

(D) By the control's price

Q32: Explanation

Correct Answer: A

- Evidence shows real performance.
- Design and operation both matter.
- Re-evaluate as conditions change.

Key Takeaway

Rate controls on evidence.

Q33: Geopolitical Risk

Question

Cloud services are hosted in a region facing increasing political instability. What should the assessment consider?

(A) Impact on availability, legal access to data, and the feasibility of relocating services

(B) Nothing; politics is not a risk

(C) Only the hosting price

(D) Only the vendor's logo

Q33: Explanation

Correct Answer: A

- External events can disrupt services.
- Legal access and sanctions may matter.
- Exit options reduce exposure.

Key Takeaway

External events belong in the assessment.

Q34: Technical Debt Assessment

Question

How should the risk from aging, unsupported systems be assessed?

(A) Consider age only

(B) Ignore business criticality

(C) Consider only the color of the casing

(D) Consider vulnerability exposure, business criticality, supportability, and the cost and time to replace

Q34: Explanation

Correct Answer: D

- Multiple factors determine risk.
- Criticality sets priority.
- Replacement timelines inform response.

Key Takeaway

Age alone is not risk; exposure and criticality are.

Q35: Data Inventory

Question

Why is a data inventory or data map important for risk assessment?

(A) It lists office plants

(B) It replaces classification

(C) It shows where sensitive data resides and flows, enabling accurate impact and exposure assessment

(D) It eliminates privacy law

Q35: Explanation

Correct Answer: C

- You cannot protect unknown data.
- Flows reveal third-party exposure.
- It supports privacy obligations.

Key Takeaway

Know where the data is.

Q36: Phishing Risk Assessment

Question

Which approach **BEST** assesses the organization's phishing risk?

(A) Count the number of employees

(B) Combine simulated phishing results, incident history, email controls, and training effectiveness

(C) Check office wall colors

(D) Review only the firewall

Q36: Explanation

Correct Answer: B

- Multiple indicators give a fuller picture.
- Simulations measure behavior.
- Controls reduce impact.

Key Takeaway

Use several lenses on human risk.

Q37: M&A Due Diligence

Question

Before acquiring a company, which risk activity is **MOST** appropriate?

(A) Skip it to speed the deal

(B) Review only the logo

(C) Ask the target to self-certify

(D) Perform cyber and IT due diligence on the target's security posture, incidents, and liabilities

Q37: Explanation

Correct Answer: D

- Acquired weaknesses become your risk.
- Findings may affect valuation or terms.
- Integration planning depends on results.

Key Takeaway

You inherit what you acquire.

Q38: Fault Tree Analysis

Question

What does fault tree analysis do?

(A) Predicts stock prices

(B) Schedules meetings

(C) Counts customer complaints

(D) Works backward from an undesired event to identify the combinations of failures that could cause it

Q38: Explanation

Correct Answer: D

- It decomposes causes logically.
- It reveals single points of failure.
- It supports design improvement.

Key Takeaway

Fault trees trace causes back from the failure.

Q39: Risk Correlation

Question

Two supposedly independent risks always materialize together. What does this suggest?

(A) It is a coincidence

(B) They are correlated through a common cause, so combined impact should be assessed

(C) The risks are unrelated

(D) The risks can be removed

Q39: Explanation

Correct Answer: B

- Correlation increases aggregate exposure.
- Common causes need shared responses.
- Independent assumptions may be wrong.

Key Takeaway

Correlated risks hit together.

Q40: Outsourced SOC Assessment

Question

A managed security operations provider monitors your environment. What should the assessment confirm?

(A) Only the logo of the provider

(B) Only the price

(C) Nothing; outsourcing removes risk

(D) Coverage, detection quality, escalation and response times, and the provider's own control assurance

Q40: Explanation

Correct Answer: D

- You depend on their effectiveness.
- Response times affect impact.
- Independent assurance provides evidence.

Key Takeaway

Outsourced monitoring still needs oversight.

Q41: Insider Risk Assessment

Question

Which factor is **MOST** relevant when assessing insider risk?

(A) The employee's favorite color

(B) Privileged access, sensitive data exposure, monitoring coverage, and organizational stressors

(C) Office size

(D) Weather

Q41: Explanation

Correct Answer: B

- Access and data determine potential impact.
- Monitoring affects detection.
- Stressors can influence behavior.

Key Takeaway

Insider risk is access plus opportunity plus motive.

Q42: Risk Appetite in Scenarios

Question

How should risk appetite be used when evaluating a scenario's result?

(A) Ignore appetite

(B) Change appetite to match the result

(C) Compare the assessed risk to appetite and tolerance to determine whether response is needed

(D) Use it only after incidents

Q42: Explanation

Correct Answer: C

- Appetite is the benchmark for acceptability.
- Tolerance gives measurable thresholds.
- Response decisions follow.

Key Takeaway

Assess against appetite.

Q43: RTO Conflicts

Question

A critical application has an RTO of 2 hours, but its database dependency has a 12-hour recovery. What should the assessment conclude?

(A) The RTO is satisfied

(B) The recovery objectives are inconsistent, so the dependency must be improved or the RTO revisited

(C) The dependency does not matter

(D) Both can be ignored

Q43: Explanation

Correct Answer: B

- The chain is only as fast as its slowest dependency.
- Gaps need response.
- Business must understand the real RTO.

Key Takeaway

Recovery is limited by the slowest dependency.

Q44: Control Dependency Failure

Question

Several controls rely on the same authentication service. What risk does this reveal?

(A) A common-mode failure, where one failure could disable multiple controls

(B) No risk

(C) Better redundancy

(D) Faster recovery

Q44: Explanation

Correct Answer: A

- Shared dependencies reduce independence.
- Defense in depth needs diversity.
- Resilience of the shared service matters.

Key Takeaway

Layers must not share one point of failure.

Q45: Scoping an Enterprise Assessment

Question

A new enterprise risk assessment is requested. What should be defined **FIRST**?

(A) The font of the report

(B) Scope, objectives, criteria, and stakeholders, aligned with business priorities

(C) The final conclusions

(D) Nothing; begin immediately

Q45: Explanation

Correct Answer: B

- Scope determines effort and relevance.
- Criteria ensure consistency.
- Stakeholders provide input and ownership.

Key Takeaway

Scope before scoring.

Q46: Assessment Documentation

Question

A risk assessment is complete. Which documentation practice is **BEST**?

(A) Keep conclusions only

(B) Delete the working papers

(C) Record scope, methodology, assumptions, data sources, results, and limitations so the assessment can be repeated and challenged

(D) Record nothing to avoid liability

Q46: Explanation

Correct Answer: C

- Documentation enables review.
- Assumptions explain differences over time.
- Transparency builds credibility.

Key Takeaway

Document so it can be reviewed and repeated.

Q47: Control Deficiency Severity

Question

Testing finds a control failure. How should its severity be determined?

(A) By considering the likelihood and magnitude of the potential impact and the presence of compensating controls

(B) By the length of the test report

(C) By who found it

(D) By the tester's mood

Q47: Explanation

Correct Answer: A

- Severity reflects risk, not volume.
- Compensating controls can lower impact.
- Consistent criteria improve prioritization.

Key Takeaway

Severity = risk-based judgment.

Q48: Amber and Red Thresholds

Question

A KRI uses green, amber, and red zones. What should happen when it enters amber?

(A) Ignore it until red

(B) Investigate the trend and prepare responses before it reaches red, per the defined procedure

(C) Hide the indicator

(D) Reset the zones

Q48: Explanation

Correct Answer: B

- Amber is an early warning.
- Early action prevents breaches.
- Procedures define who acts.

Key Takeaway

Amber is time to act, not time to wait.

Q49: Metrics Gaming

Question

Teams close tickets quickly by marking them resolved without fixing the cause. What is the **BEST** response?

(A) Add more ticket targets

(B) Reward speed only

(C) Ignore it

(D) Review metric design to reward real outcomes, and add quality checks such as reopen rates

Q49: Explanation

Correct Answer: D

- What gets measured shapes behavior.
- Quality checks counter gaming.
- Outcome-based measures are more meaningful.

Key Takeaway

Measure outcomes to avoid gamed metrics.

Q50: Audit Committee Reporting

Question

What should risk reporting to the audit committee emphasize?

(A) Technical logs

(B) Significant risks, control weaknesses, remediation progress, and independent assurance results

(C) Minor incidents only

(D) Staff birthdays

Q50: Explanation

Correct Answer: B

- The committee oversees risk and controls.
- Progress shows accountability.
- Material issues need attention.

Key Takeaway

Give the committee what it needs to oversee.

Q51: Crisis Communication

Question

During a major incident, which communication practice is **BEST**?

(A) Provide timely, accurate, coordinated messages through designated spokespeople

(B) Let everyone speak freely

(C) Say nothing

(D) Provide speculation

Q51: Explanation

Correct Answer: A

- Consistent messages protect trust.
- Designated spokespeople avoid mixed statements.
- Accuracy matters more than speed alone.

Key Takeaway

One voice, accurate facts.

Q52: Vendor Scorecards

Question

What is the benefit of vendor performance and risk scorecards?

(A) They replace contracts

(B) They hide issues

(C) They provide consistent, ongoing visibility into vendor performance against service and control expectations

(D) They end oversight

Q52: Explanation

Correct Answer: C

- Consistent measures allow comparison.
- Trends show deteriorating vendors.
- Results support renewal decisions.

Key Takeaway

Scorecards turn vendor oversight into data.

Q53: Contract Renewal

Question

A critical vendor contract is up for renewal. What risk activity should occur?

(A) Auto-renew without review

(B) Ignore past issues

(C) Skip the risk review

(D) Reassess the vendor's risk, performance, and incidents, and update terms accordingly

Q53: Explanation

Correct Answer: D

- Conditions may have changed.
- Renewal is leverage for improvement.
- Update security and exit terms.

Key Takeaway

Renewal is a risk checkpoint.

Q54: Testing the Exit Plan

Question

A cloud exit plan exists but has never been exercised. What is the **BEST** recommendation?

(A) Assume it works

(B) Test the exit plan, at least in part, to confirm that data and services can be moved within acceptable time

(C) Delete the plan

(D) Never test

Q54: Explanation

Correct Answer: B

- Untested plans may fail.
- Testing reveals dependencies.
- Results inform contract terms.

Key Takeaway

Test the exit before you need it.

Q55: Change Failure Rate

Question

What does a high change failure rate indicate from a risk perspective?

(A) Excellent controls

(B) No risk

(C) Faster innovation only

(D) Weak change testing or approval controls, increasing the risk of outages and incidents

Q55: Explanation

Correct Answer: D

- Failures cause disruption.
- Process weaknesses may be the cause.
- Improvements reduce risk.

Key Takeaway

Failed changes signal weak change control.

Q56: Patch SLA

Question

The organization defines time limits for patching by severity. What is the main benefit?

(A) It removes the need to patch

(B) It sets clear expectations and enables measurement and escalation when deadlines are missed

(C) It delays all patches

(D) It hides vulnerabilities

Q56: Explanation

Correct Answer: B

- Service levels create accountability.
- Measurement shows compliance.
- Escalation addresses delays.

Key Takeaway

Define deadlines, then measure them.

Q57: Vulnerability Aging

Question

A report shows many critical vulnerabilities open for over 180 days. What is the **BEST** interpretation?

(A) The environment is secure

(B) Vulnerabilities fix themselves

(C) Remediation processes are not effective, so exposure and likely audit findings are rising

(D) Age does not matter

Q57: Explanation

Correct Answer: C

- Aging shows remediation weakness.
- Attackers favor known vulnerabilities.
- Escalation and resourcing may be needed.

Key Takeaway

Aged criticals are an alarm bell.

Q58: Mean Time to Remediate

Question

Which metric **BEST** reflects the speed of fixing vulnerabilities?

(A) Number of scans run

(B) Mean time to remediate by severity

(C) Number of tools bought

(D) Number of dashboards

Q58: Explanation

Correct Answer: B

- It measures outcome speed.
- Segmenting by severity prioritizes risk.
- Trends show improvement.

Key Takeaway

Measure how quickly you fix, not how often you look.

Q59: Business Case for Controls

Question

How should the risk practitioner **BEST** support a business case for a new control?

(A) Use fear and uncertainty only

(B) Show vendor slides only

(C) Show the risk reduction, costs, alternatives, and alignment with appetite and objectives

(D) Skip cost analysis

Q59: Explanation

Correct Answer: C

- Decision makers need balanced information.
- Alternatives demonstrate rigor.
- Alignment with objectives gains support.

Key Takeaway

Support controls with evidence and options.

Q60: Return on Security Investment

Question

How can a security investment's value be **BEST** expressed to executives?

(A) By the number of features

(B) As reduction in expected loss and risk exposure relative to cost, along with strategic benefits

(C) By the vendor's reputation only

(D) By the length of the report

Q60: Explanation

Correct Answer: B

- Executives think in value and exposure.
- Expected loss reduction is comparable to cost.
- Non-financial benefits add context.

Key Takeaway

Speak in risk reduced per dollar spent.

Q61: Budget Prioritization by Risk

Question

Competing proposals request budget. How should a risk-based allocation work?

(A) Fund the loudest sponsor

(B) Rank proposals by the risk they reduce relative to appetite and cost, then allocate to highest value

(C) Split evenly always

(D) Fund the newest technology

Q61: Explanation

Correct Answer: B

- Risk reduction guides value.
- Appetite sets urgency.
- Transparency builds confidence.

Key Takeaway

Allocate by risk reduction.

Q62: Risk Reduction Verification

Question

After a big risk reduction project, how can the organization verify the result?

(A) Assume success

(B) Rely on the project team's statement

(C) Skip verification

(D) Re-assess the risk using updated evidence, testing, and indicators and compare to the baseline

Q62: Explanation

Correct Answer: D

- Evidence confirms outcomes.
- Baseline comparison shows change.
- Update the register.

Key Takeaway

Verify the benefit with evidence.

Q63: Testing Independence

Question

Who should **ideally** test the effectiveness of a key control?

(A) The control operator alone

(B) The vendor selling it

(C) Someone independent of the control's operation, such as the second or third line

(D) Nobody

Q63: Explanation

Correct Answer: C

- Independence improves objectivity.
- Operators may overlook problems.
- Self-testing is useful but limited.

Key Takeaway

Independent testing is more credible.

Q64: Sampling Bias

Question

A tester picks only the cleanest-looking records as a sample. What is the issue?

(A) Selection bias may overstate control effectiveness, so sampling should be representative or random

(B) No issue

(C) The sample is too accurate

(D) It improves quality

Q64: Explanation

Correct Answer: A

- Biased samples mislead.
- Random or risk-based sampling is better.
- Document the method.

Key Takeaway

Do not cherry-pick your sample.

Q65: SLA Monitoring

Question

A provider's reports show all service levels met, but users report frequent outages. What should the practitioner do?

(A) Trust the provider fully

(B) Ignore users

(C) Cancel immediately without facts

(D) Validate the provider's measurement methods and compare with independent or user data

Q65: Explanation

Correct Answer: D

- Reports may exclude relevant outages.
- Independent data gives perspective.
- Contract definitions matter.

Key Takeaway

Verify what vendors report.

Q66: Automated Reporting

Question

What is a risk of heavy automation in risk reporting?

(A) Reports become too accurate

(B) It removes all errors

(C) Errors in data or logic can propagate unnoticed, so validation and ownership remain essential

(D) It needs no oversight

Q66: Explanation

Correct Answer: C

- Automation scales mistakes.
- Data lineage should be understood.
- Humans must review exceptions.

Key Takeaway

Automate the work, not the accountability.

Q67: Drill-Down Reports

Question

Why provide drill-down capability in risk dashboards?

(A) It lets decision makers move from summary to supporting detail for understanding and challenge

(B) To confuse the audience

(C) To hide data

(D) To increase meetings

Q67: Explanation

Correct Answer: A

- Summaries need credible detail.
- Detail enables verification.
- Different users need different depth.

Key Takeaway

Summary on top, evidence underneath.

Q68: Risk-Adjusted Decisions

Question

Which approach **BEST** reflects risk-adjusted decision making for a new initiative?

(A) Consider only benefits

(B) Consider only risks

(C) Evaluate expected benefits against the associated risks, including residual risk, before approval

(D) Decide by seniority

Q68: Explanation

Correct Answer: C

- Balanced evaluation leads to better outcomes.
- Residual risk should be known.
- Owners approve within appetite.

Key Takeaway

Weigh benefits against risk, not instead of it.

Q69: Third-Party Breach Response

Question

A vendor breach exposes your employee data. What should the risk practitioner prioritize?

(A) Wait for the news

(B) Rate the vendor as perfect

(C) Assess impact, ensure containment and notification obligations are met, and update the vendor risk

(D) Do nothing

Q69: Explanation

Correct Answer: C

- Obligations may be time-sensitive.
- Impact informs response.
- Findings update vendor tiering.

Key Takeaway

Respond to the incident, then learn from it.

Q70: Control Framework Mapping

Question

The organization must comply with several standards. What is the benefit of mapping controls across frameworks?

(A) It reduces duplication by showing where one control satisfies multiple requirements

(B) It creates more controls

(C) It removes compliance duties

(D) It hides gaps

Q70: Explanation

Correct Answer: A

- Efficiency improves.
- Common controls simplify testing.
- Gaps are easier to see.

Key Takeaway

Map once, comply many times.

Q71: Testing Frequency

Question

How should the frequency of control testing be determined?

(A) Same for all controls

(B) Only when convenient

(C) Based on the control's criticality, risk level, and previous results

(D) Only after incidents

Q71: Explanation

Correct Answer: C

- Higher risk needs more frequent testing.
- Previous failures justify closer attention.
- Resources are focused.

Key Takeaway

Test the important controls more often.

Q72: Exception Register

Question

Why maintain an exception register with expiry dates?

(A) To ensure exceptions are visible, reviewed, and not allowed to become permanent unmanaged risk

(B) To prove everyone follows policy

(C) To delay all reviews

(D) To remove owners

Q72: Explanation

Correct Answer: A

- Visibility supports oversight.
- Expiry forces review.
- Compensating controls can be verified.

Key Takeaway

Exceptions should expire.

Q73: Escalating Under Pressure

Question

The business pressures the practitioner not to escalate a major risk before a product launch. What should be done?

(A) Escalate according to policy, presenting facts and options so leadership can decide knowingly

(B) Stay silent

(C) Delete the risk

(D) Delay until after launch

Q73: Explanation

Correct Answer: A

- Material risk requires timely escalation.
- Facts support decisions.
- Leadership can accept risk deliberately.

Key Takeaway

Do not let launch dates hide risks.

Q74: Single Version of Truth

Question

Different reports give different risk numbers for the same area. What is the **BEST** fix?

(A) Allow every report to differ

(B) Establish authoritative data sources, definitions, and a single reporting process

(C) Hide reports

(D) Pick numbers randomly

Q74: Explanation

Correct Answer: B

- Consistent data supports trust.
- Definitions avoid disputes.
- Single processes reduce errors.

Key Takeaway

One set of numbers.

Q75: Post-Incident Report

Question

What should a post-incident report to management primarily contain?

(A) Blame assignments only

(B) Technical commands only

(C) A single sentence

(D) Root cause, impact, response effectiveness, lessons learned, and corrective actions with owners

Q75: Explanation

Correct Answer: D

- Reports drive improvement.
- Owners and dates ensure follow-up.
- Lessons update the risk register.

Key Takeaway

Close the loop with actions and owners.

Q76: Business Continuity Metrics

Question

Which metric **BEST** indicates continuity readiness?

(A) Number of plans printed

(B) Number of staff trained once

(C) Results of exercises against recovery objectives, and the closure of identified gaps

(D) Plan page count

Q76: Explanation

Correct Answer: C

- Exercises prove capability.
- Gap closure shows improvement.
- Objectives tie to business needs.

Key Takeaway

Readiness is demonstrated, not documented.

Q77: Policy Violation Trends

Question

Reports show increasing policy violations in one department. What should the practitioner do?

(A) Ignore it

(B) Analyze root causes with the owner and address training, process, or incentive issues

(C) Fire the department

(D) Delete the data

Q77: Explanation

Correct Answer: B

- Trends signal systemic problems.
- Root causes may be non-obvious.
- Targeted fixes work better than blame.

Key Takeaway

Trends point to systemic causes.

Q78: Closing Risk Issues

Question

When may a risk issue be closed in the register?

(A) When the owner stops responding

(B) When response actions are complete and verified, and the residual risk is within appetite or formally accepted

(C) When the deadline passes

(D) When the report is filed

Q78: Explanation

Correct Answer: B

- Closure needs evidence.
- Residual risk must be within appetite or accepted.
- Verification prevents false closure.

Key Takeaway

Close risks on evidence, not on dates.

Q79: Identity Lifecycle

Question

Which practice **BEST** manages user access throughout an employee's tenure?

(A) Grant access once and never review

(B) Joiner, mover, and leaver processes tied to HR events, with periodic access reviews

(C) Let users request any access by phone

(D) Share accounts in teams

Q79: Explanation

Correct Answer: B

- Job changes alter access needs.
- HR events are reliable triggers.
- Reviews catch accumulated privileges.

Key Takeaway

Access should follow the person's role over time.

Q80: Privileged Access Management

Question

Which capability is **MOST** valuable in privileged access management?

(A) Permanent shared admin passwords

(B) Unlimited sessions without logs

(C) Just-in-time elevation, credential vaulting, and session recording

(D) Local admin for everyone

Q80: Explanation

Correct Answer: C

- Limiting standing privilege reduces exposure.
- Vaulting protects credentials.
- Recording supports accountability.

Key Takeaway

Make privilege temporary, controlled, and recorded.

Q81: Session Management

Question

Users leave sensitive applications logged in on shared computers. Which control **BEST** reduces risk?

(A) Automatic session timeouts and re-authentication for sensitive actions

(B) Longer sessions

(C) No timeouts

(D) Posters about locking screens only

Q81: Explanation

Correct Answer: A

- Timeouts limit unauthorized use.
- Step-up authentication protects critical actions.
- Technical controls are more reliable than reminders.

Key Takeaway

Do not rely on users to log out.

Q82: Network Access Control

Question

Unknown personal devices connect to the corporate network. What **BEST** addresses this?

(A) Disable all logging

(B) Print the Wi-Fi password on walls

(C) Allow all devices

(D) Network access control that authenticates devices and checks their compliance before granting access

Q82: Explanation

Correct Answer: D

- Device identity and posture matter.
- Non-compliant devices can be isolated.
- Visibility supports inventory.

Key Takeaway

Authenticate the device, not only the user.

Q83: Microsegmentation

Question

After a breach, attackers moved freely among servers. Which approach **BEST** limits future lateral movement?

(A) A flat network

(B) More shared credentials

(C) Microsegmentation with least-privilege network policies between workloads

(D) Fewer logs

Q83: Explanation

Correct Answer: C

- Fine-grained segments contain compromise.
- Policies restrict necessary paths only.
- Monitoring detects unusual flows.

Key Takeaway

Contain the blast radius.

Q84: Security Automation

Question

The security team is overwhelmed by repetitive tasks. Which capability **BEST** helps?

(A) Security orchestration, automation, and response for routine, well-defined workflows

(B) Hiring no one

(C) Ignoring alerts

(D) Disabling detection

Q84: Explanation

Correct Answer: A

- Automation handles repeat tasks.
- Analysts focus on complex work.
- Playbooks must be reviewed.

Key Takeaway

Automate the routine; keep humans for judgment.

Q85: Threat Hunting

Question

What is the primary goal of proactive threat hunting?

(A) To wait for alerts

(B) To replace all tools

(C) To reduce logging

(D) To search for hidden threats that automated detection may have missed

Q85: Explanation

Correct Answer: D

- Hunting assumes compromise is possible.
- Hypotheses guide searches.
- Findings improve detections.

Key Takeaway

Hunt for what the alerts did not catch.

Q86: Operational Technology

Question

A plant's control systems cannot be patched frequently without risking production. What is the **BEST** approach?

(A) Treat it exactly like office IT

(B) Ignore it

(C) Use network segmentation, access control, monitoring, and compensating controls tailored to safety and availability

(D) Connect it directly to the internet

Q86: Explanation

Correct Answer: C

- OT prioritizes safety and availability.
- Segmentation reduces exposure.
- Monitoring detects anomalies.

Key Takeaway

OT security protects safety first.

Q87: Mobile App Security

Question

A company builds a mobile app handling sensitive data. Which practice is **MOST** important?

(A) Secure development, secure data storage, strong authentication, and regular testing

(B) A colorful icon

(C) Larger downloads

(D) Fewer updates

Q87: Explanation

Correct Answer: A

- Mobile devices can be lost or compromised.
- Data storage should be minimized and protected.
- Testing finds weaknesses.

Key Takeaway

Build security into the app lifecycle.

Q88: API Protection

Question

Public APIs are being abused with excessive requests. Which control **BEST** helps?

(A) Disable authentication

(B) Authentication, authorization, rate limiting, and monitoring through an API gateway

(C) Unlimited requests

(D) Public documentation only

Q88: Explanation

Correct Answer: B

- Gateways enforce policies.
- Rate limits reduce abuse.
- Monitoring shows misuse.

Key Takeaway

Control who calls the API and how often.

Q89: Authorization Standards

Question

An application lets users sign in with another provider and grants limited access to their data. Which standard commonly supports delegated authorization?

(A) OAuth

(B) A cabling standard

(C) A fax protocol

(D) A paper format

Q89: Explanation

Correct Answer: A

- OAuth delegates limited access.
- Scopes limit what is granted.
- Tokens should be protected.

Key Takeaway

OAuth delegates access without sharing passwords.

Q90: SQL Injection

Question

Which practice **BEST** prevents SQL injection?

(A) Longer passwords

(B) Bigger databases

(C) Parameterized queries with input validation

(D) More servers

Q90: Explanation

Correct Answer: C

- Parameters separate data from commands.
- Validation reduces risk further.
- Least privilege limits impact.

Key Takeaway

Never build queries by concatenating user input.

Q91: Code Signing

Question

What is the main purpose of code signing?

(A) To verify the publisher and that the code has not been altered since signing

(B) To make code run faster

(C) To encrypt all data

(D) To reduce file size

Q91: Explanation

Correct Answer: A

- Signatures provide authenticity and integrity.
- Private keys must be protected.
- Verification happens at installation or run time.

Key Takeaway

Signed code proves origin and integrity.

Q92: Software Bill of Materials

Question

Why is a software bill of materials valuable?

(A) It replaces testing

(B) It lists components in software so that vulnerable ones can be identified quickly when issues are disclosed

(C) It guarantees security

(D) It lists employees

Q92: Explanation

Correct Answer: B

- Visibility enables fast response.
- Supplier components are included.
- It supports supply chain risk management.

Key Takeaway

Know the ingredients of your software.

Q93: Key Rotation

Question

Why rotate encryption keys periodically?

(A) To make keys longer

(B) To avoid backups

(C) To confuse administrators

(D) To limit the amount of data exposed by a compromised key and to meet policy or regulatory requirements

Q93: Explanation

Correct Answer: D

- Rotation limits exposure windows.
- Compromise may be undetected.
- Procedures must handle old data.

Key Takeaway

Rotate keys to limit exposure.

Q94: Data Masking

Question

Analysts need realistic data for reports but should not see actual personal details. Which control fits?

(A) Share raw data widely

(B) Data masking or tokenization of sensitive fields

(C) Email full databases

(D) Remove all access controls

Q94: Explanation

Correct Answer: B

- Masking reduces exposure.
- Tokenization replaces values with surrogates.
- Access to originals stays restricted.

Key Takeaway

Mask what analysts do not need to see.

Q95: Secure File Transfer

Question

Sensitive files are regularly emailed to partners. What is the **BEST** improvement?

(A) Continue emailing

(B) Use public file sharing without controls

(C) Use secure, encrypted file transfer with authentication and logging

(D) Print and mail

Q95: Explanation

Correct Answer: C

- Email is often unencrypted.
- Controlled transfers provide traceability.
- Authentication ensures only intended recipients.

Key Takeaway

Use controlled channels for sensitive data.

Q96: Software License Compliance

Question

Audits show the company uses more software licenses than it has purchased. What risk does this create?

(A) No risk

(B) Better security

(C) Faster performance

(D) Legal and financial exposure from non-compliance with license terms

Q96: Explanation

Correct Answer: D

- Vendors can audit and claim penalties.
- An inventory supports compliance.
- Governance should track entitlements.

Key Takeaway

Unlicensed use creates legal and financial risk.

Q97: Virtualization Sprawl

Question

Virtual machines are created without lifecycle management and many are forgotten. What is the risk?

(A) Lower attack surface

(B) Better monitoring

(C) No impact

(D) Unpatched, unmonitored systems that increase attack surface and cost

Q97: Explanation

Correct Answer: D

- Forgotten systems escape controls.
- Inventory and lifecycle processes help.
- Decommissioning reduces exposure.

Key Takeaway

Forgotten VMs are unmanaged risk.

Q98: Hypervisor Security

Question

Why is hypervisor security especially important?

(A) It affects only one VM

(B) It has no connection to guests

(C) A compromised hypervisor could affect all the virtual machines it hosts

(D) It only affects printing

Q98: Explanation

Correct Answer: C

- The hypervisor is a high-value target.
- Hardening and patching are critical.
- Access should be tightly restricted.

Key Takeaway

Protect the layer beneath all the VMs.

Q99: Cloud Exit Data

Question

When ending a cloud service, what should be verified regarding data?

(A) That all data has been returned or migrated and then securely deleted by the provider, with confirmation

(B) That the provider keeps the data indefinitely

(C) That nothing happens

(D) That logs are disabled

Q99: Explanation

Correct Answer: A

- Data may remain in provider systems.
- Contracts should specify deletion.
- Evidence of deletion supports compliance.

Key Takeaway

Verify deletion when you leave.

Q100: Tokenization of Payment Data

Question

A merchant wants to reduce the scope and risk of storing card numbers. Which control **BEST** helps?

(A) Storing card numbers in a spreadsheet

(B) Emailing card numbers to staff

(C) Writing numbers on tickets

(D) Tokenization, replacing card numbers with non-sensitive tokens held by a secure provider

Q100: Explanation

Correct Answer: D

- Tokens have no exploitable value on their own.
- Less stored card data means a smaller compliance scope.
- The token vault must be strongly protected.

Key Takeaway

If you do not store it, you cannot lose it.

Exam Mindset Summary

Remember These Core Principles

- **Business First:** Risk is defined by its effect on business objectives.
- **Owners Decide:** Practitioners inform; owners accept, mitigate, transfer, or avoid.
- **Three Lines:** The first line owns risk, the second oversees, and the third gives independent assurance.
- **Ethics Matter:** Honesty, independence, and confidentiality underpin credible risk advice.
- **Evidence Over Opinion:** Use data, scenarios, and calibrated ratings.
- **Proportionality:** Controls should fit the risk and its cost.
- **Accountability Cannot be Outsourced:** Vendors and cloud providers share duties, but accountability remains with the organization.

Good Luck on Your CRISC Exam!

Real exam questions test your ability to apply these concepts in practical, real-world scenarios.